

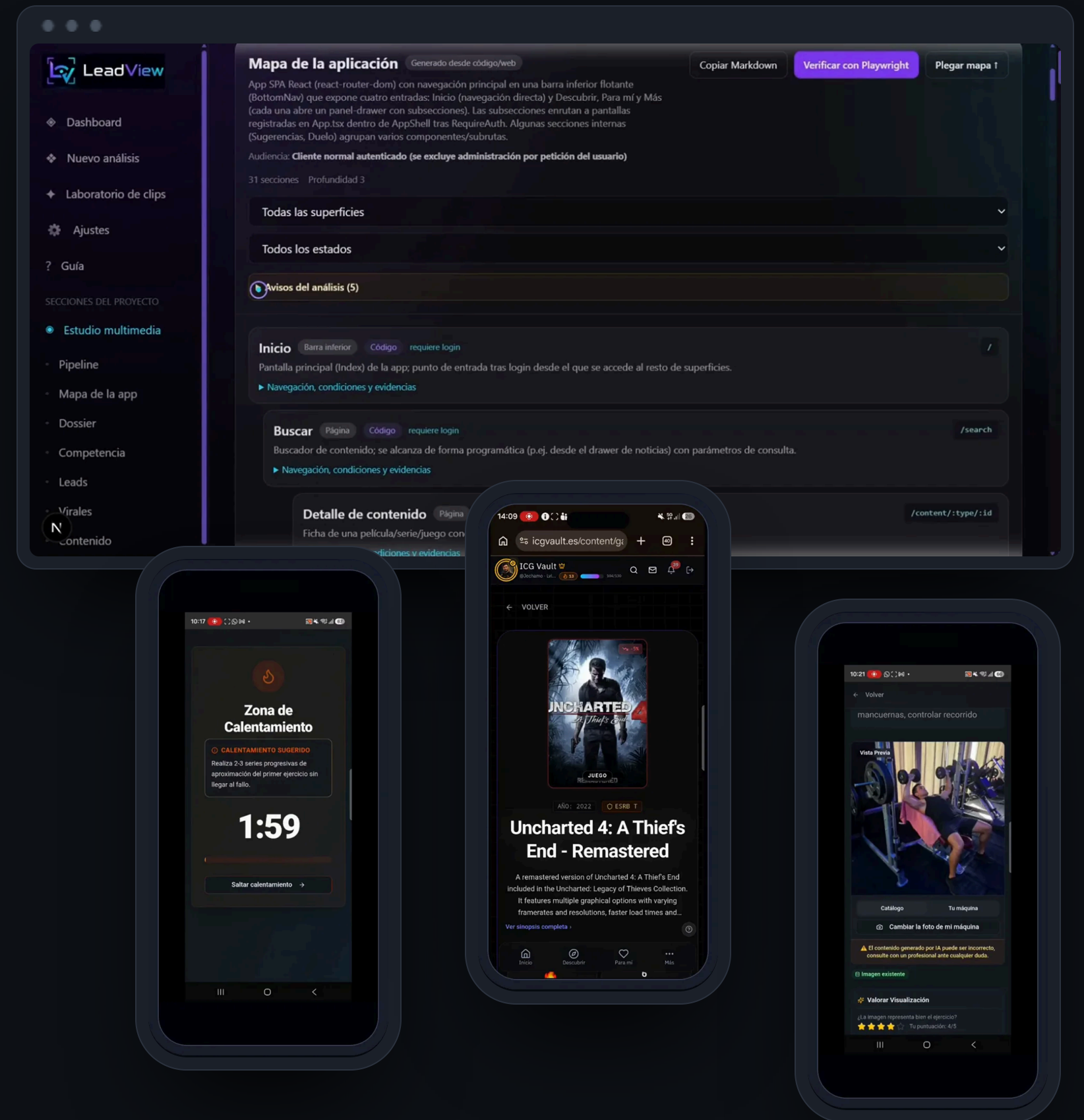
Del máster a *producción*

Ingeniería de software dirigida por especificaciones con agentes de IA, aplicada a tres productos reales.

Jorge Chamorro

Máster en Desarrollo de Software con IA

jecho.github.io/TFM ▶ Vídeo del TFM · 17:09



Un método y tres productos *reales*.

NÚCLEO · EL MÉTODO

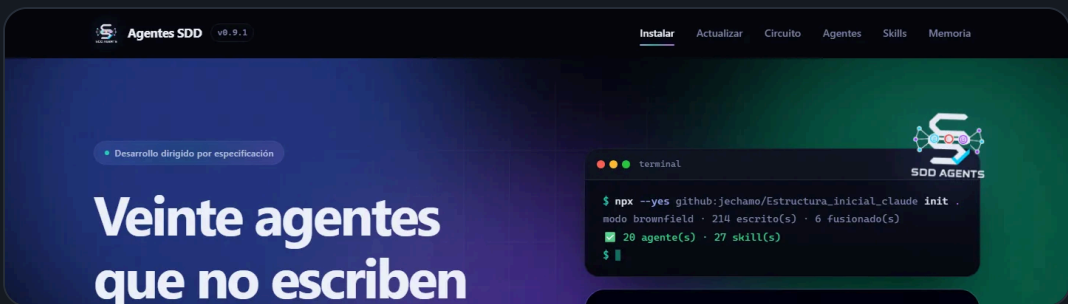
Sistema SDD/TDD con agentes

Kit instalable con `npx` que gobierna a los agentes: especificación primero, TDD con evidencia y la persona decide en seis puertas.

20 agentes 27 skills 6 gates 375 comprobaciones

github.com/jechamo/Estructura_inicial_claude
jechamo.github.io/Estructura_inicial_claude

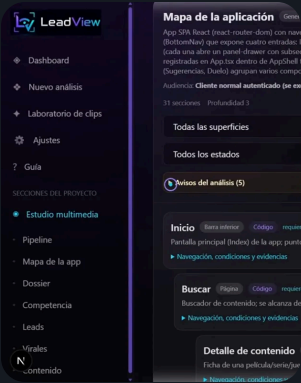
ACCESO kit instalable, sin login



crea

especifica
y evoluciona

audita
y evoluciona



RRSS Studio

GREENFIELD · LOCAL

Nació con el método: analiza un producto y crea contenido para redes con IA.

github.com/jechamo/rrss-automation-app

ACCESO app local, sin login



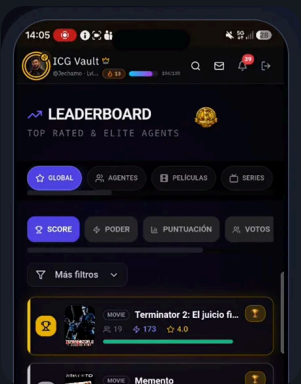
ChaFit

EN PRODUCCIÓN · WEB, IOS Y ANDROID

Entrenamiento para clientes, entrenadores y gimnasios, con 7 specs y TDD.

github.com/jechamo/chafit360 chafit.es

DEMO `client3@demo.chafit.es` · `demo123456`



ICG Vault

EN PRODUCCIÓN · WEB, IOS Y ANDROID

Red social de cine, series y videojuegos, auditada con el modelo SDD.

github.com/jechamo/icgbolt icgvault.es

DEMO `Pepis` · `demo123456`

Los agentes escriben deprisa. *Sin método*, esa velocidad se paga.

01

Se autocertifican

El mismo agente planifica, implementa y se da por bueno.

02

Contratos implícitos

La IA devolvía 7 u 8 columnas; la app esperaba 9: **317 filas** desplazadas en ChaFit.

03

Sin rastro

Nadie sabe por qué se decidió algo ni qué llegó a producción.

04

Seguridad al final

Permisos demasiado amplios en la capa de datos, descubiertos tarde.

ChaFit e ICG Vault nacieron en un generador *low-code* y crecieron a base de chat. Funcionaban, pero no eran mantenibles.

La spec manda, el test demuestra *y la persona decide.*

SDD

Especificación primero

Nada de código sin spec aprobada: EARS, Gherkin, seguridad y usabilidad.

TDD

El rojo, a la vista

RED demostrado → GREEN → REFACTOR.
«Pasa» sin ejecutar no cuenta.

Hooks + CLI

Verificación fuera del modelo

Territorios, trazas, secretos y gates los comprueba código, no el agente.

6 gates

La persona decide

Producto, arquitectura, spec, diseño, plan y entrega.

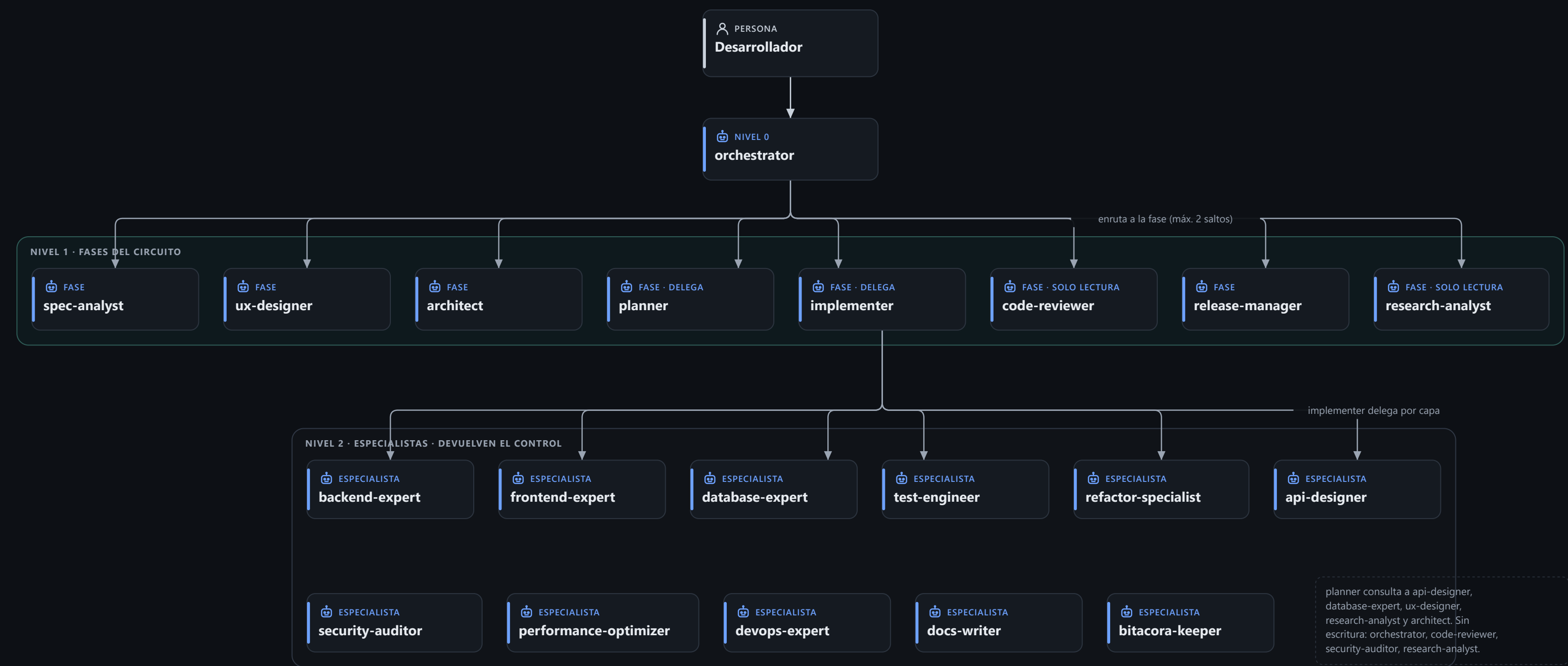
Un kit instalable con [npx](#) en cualquier repositorio · Claude Code · Copilot · Cursor · Codex · Gemini CLI · Antigravity · Node ≥ 18, sin dependencias.

Diez fases, seis puertas, *tres niveles*.



Reglas duras: ningún código sin spec aprobada · TDD con RED demostrado · «pasa» sin ejecución no es un resultado · antes de commit run --fast y antes de push run --slow · toda tarea enlaza spec, criterio, tarea, test y evidencia · nunca se leen ni escriben secretos.

20 agentes. Solo 3 delegan. *Quien juzga no escribe.*



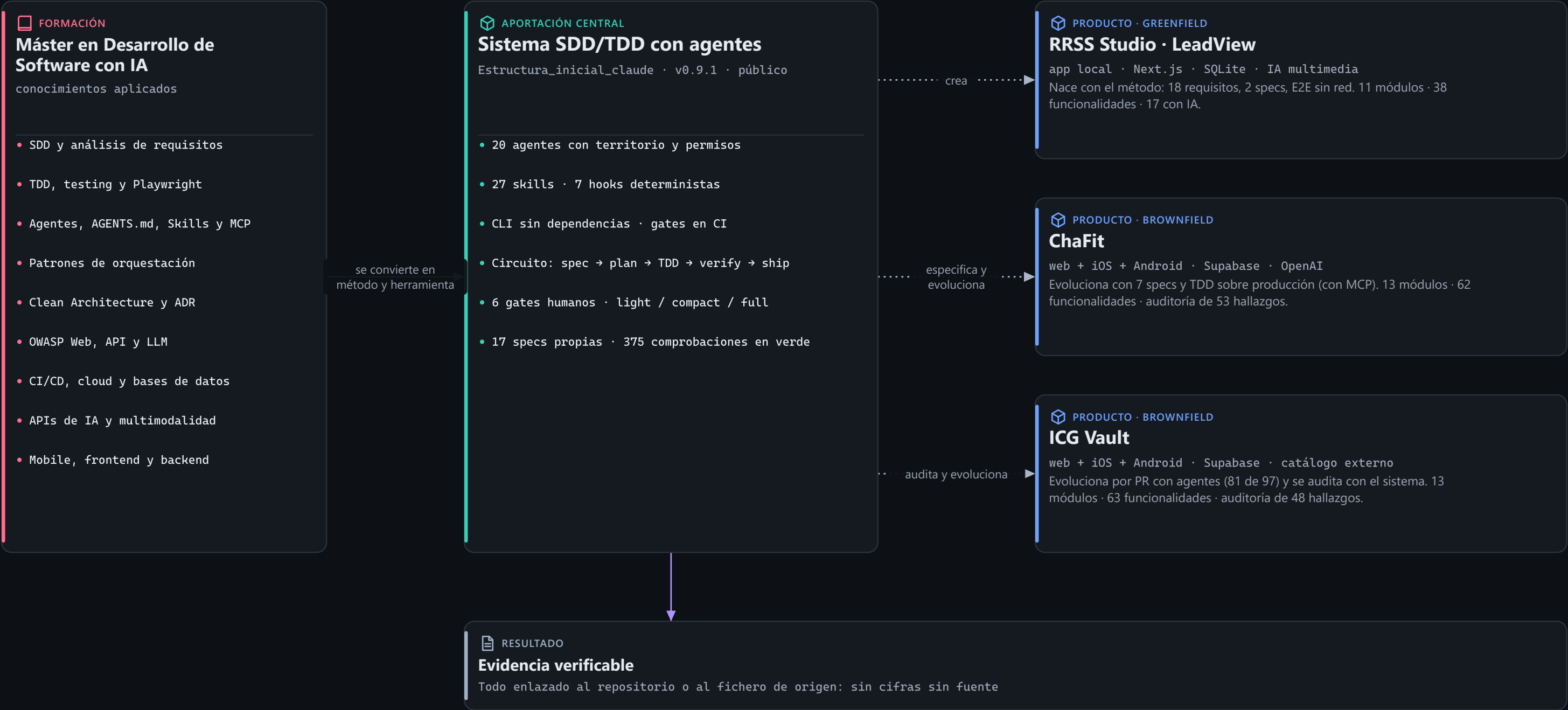
Agentes que proponen, *scripts que verifican.*

- **spec-analyst** escribe requisitos EARS y criterios Gherkin. **Gate 3**
- **planner**: plan, datos, contratos y tareas atómicas, cada una con su test. **Gate 5**
- **implementer**: TDD tarea a tarea; guard-write y guard-bash vigilan y los hooks registran.
- **code-reviewer** y **security-auditor**, de solo lectura: GO sin CRÍTICO ni ALTO.
- **release-manager**: PR, CHANGELOG y reversión. **Gate 6**

```
# ChaFit · spec 001 · 09/08/2026
18:25 T-001-01 deno test      RED    0/4
18:27 T-001-01 deno test      GREEN   4/4
18:34 T-001-03 filas (MCP)    RED    317 ≠ 9 celdas
18:41 T-001-03 migración      GREEN   0 inválidas
18:50 T-001-04 despliegue MCP GREEN   v22 · v6
# después de migrar
437/437 filas · 0 discrepancias
```

Evidencia real de la spec 001 de ChaFit: el rojo se demuestra antes del verde.

Un sistema, *tres aplicaciones.*



TFM · Jorae Chamorro · AS-IS

RRSS Studio · *LeadView*

Analiza tu app desde su URL y su código, estudia a tu competencia, encuentra clientes y produce vídeos verticales con IA, viendo el coste antes de gastar.

11

módulos

38

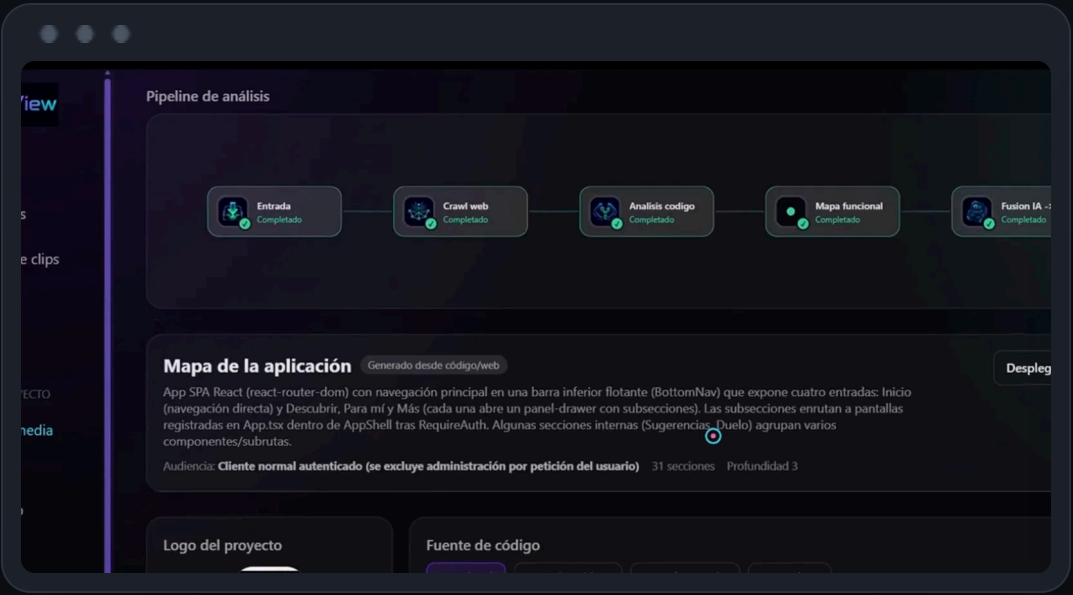
funciones

17

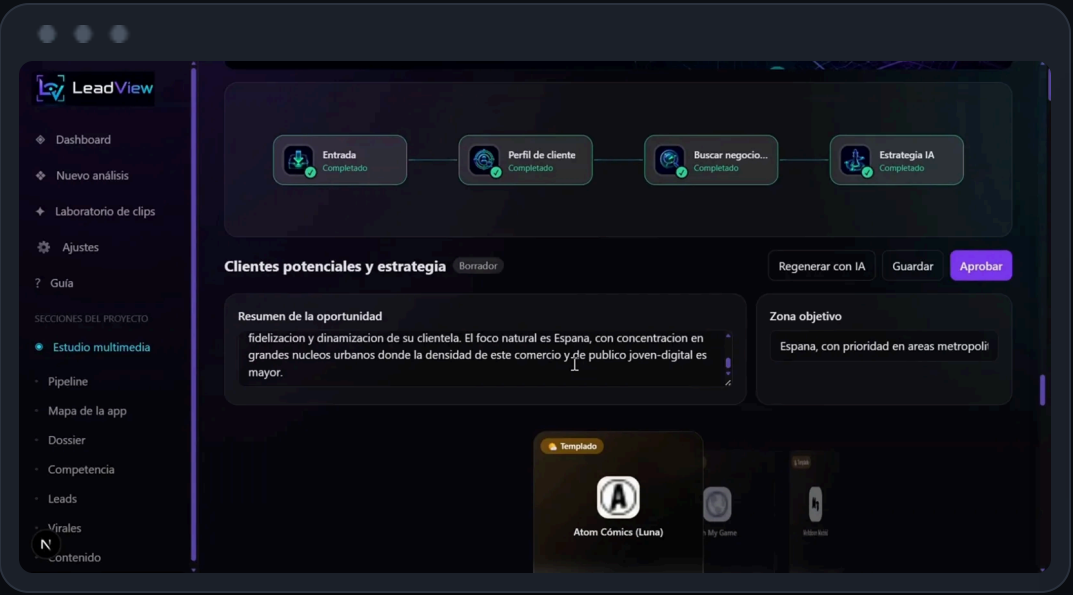
con IA

11

APIs



Análisis en vivo de un producto

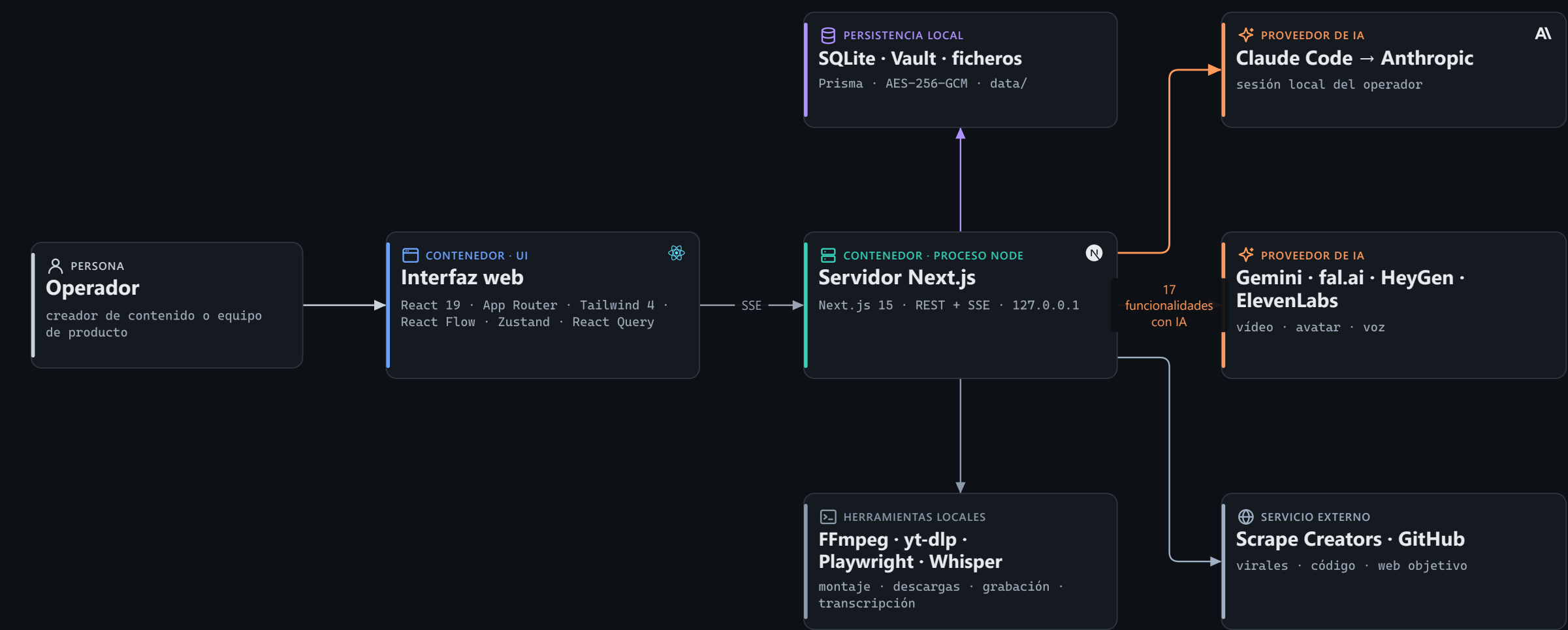


Cientes potenciales reales, con su fuente



Plan y coste antes de generar

Monolito modular local: *un proceso, muchas IA.*



Claude Code

como motor, con la sesión del operador y herramientas mínimas por tarea.

AES-256-GCM

Vault local: las claves nunca van a .env ni vuelven a la interfaz.

71 + 138

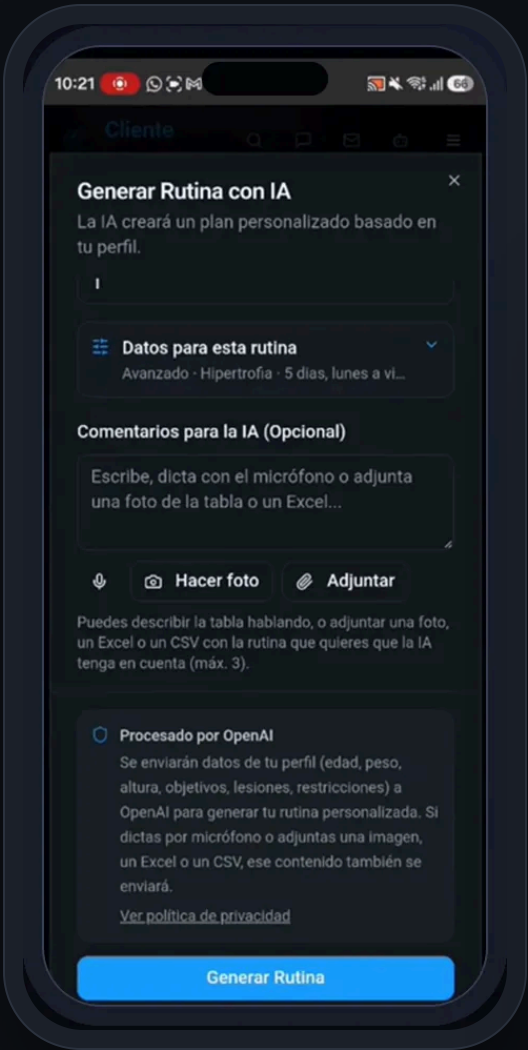
tests en verde hoy, más 9 recorridos E2E sin red.

ChaFit

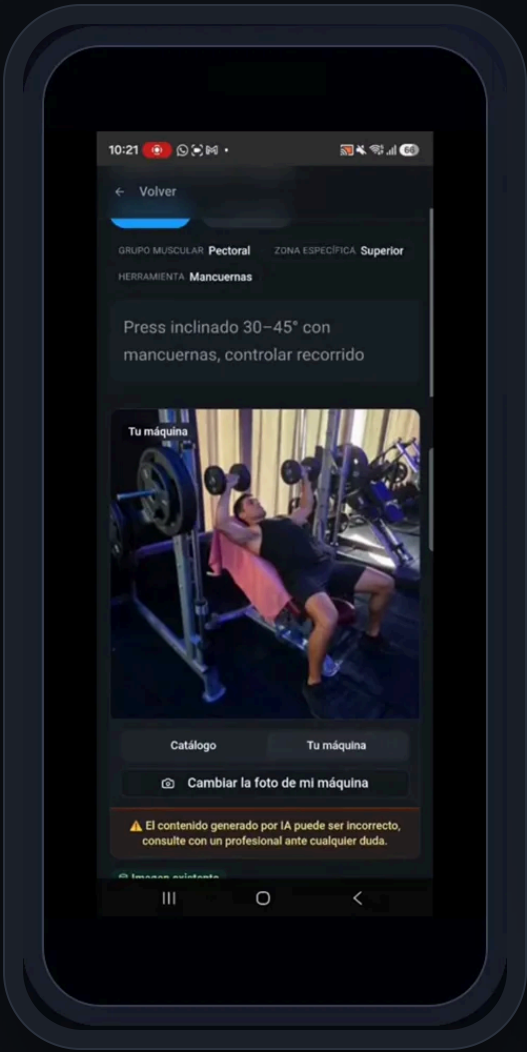
Cientes, entrenadores y gimnasios en una plataforma: rutinas y dietas con IA, ejecución guiada, la ilustración de tu propia máquina y foto al plato.

13	62	12	9
módulos	funciones	con IA	APIs

- Rutinas con IA
- Ejecución
- Catálogo de ejercicios
- Nutrición
- Progreso
- Entrenadores
- Gimnasios
- Pagos
- Comunidad



Rutina por voz o foto



Ficha con «tu máquina»

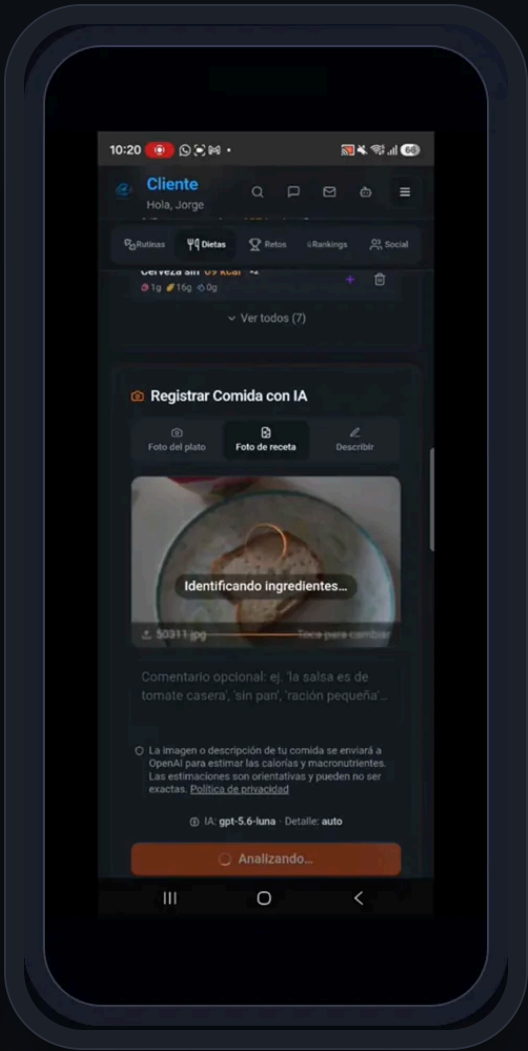
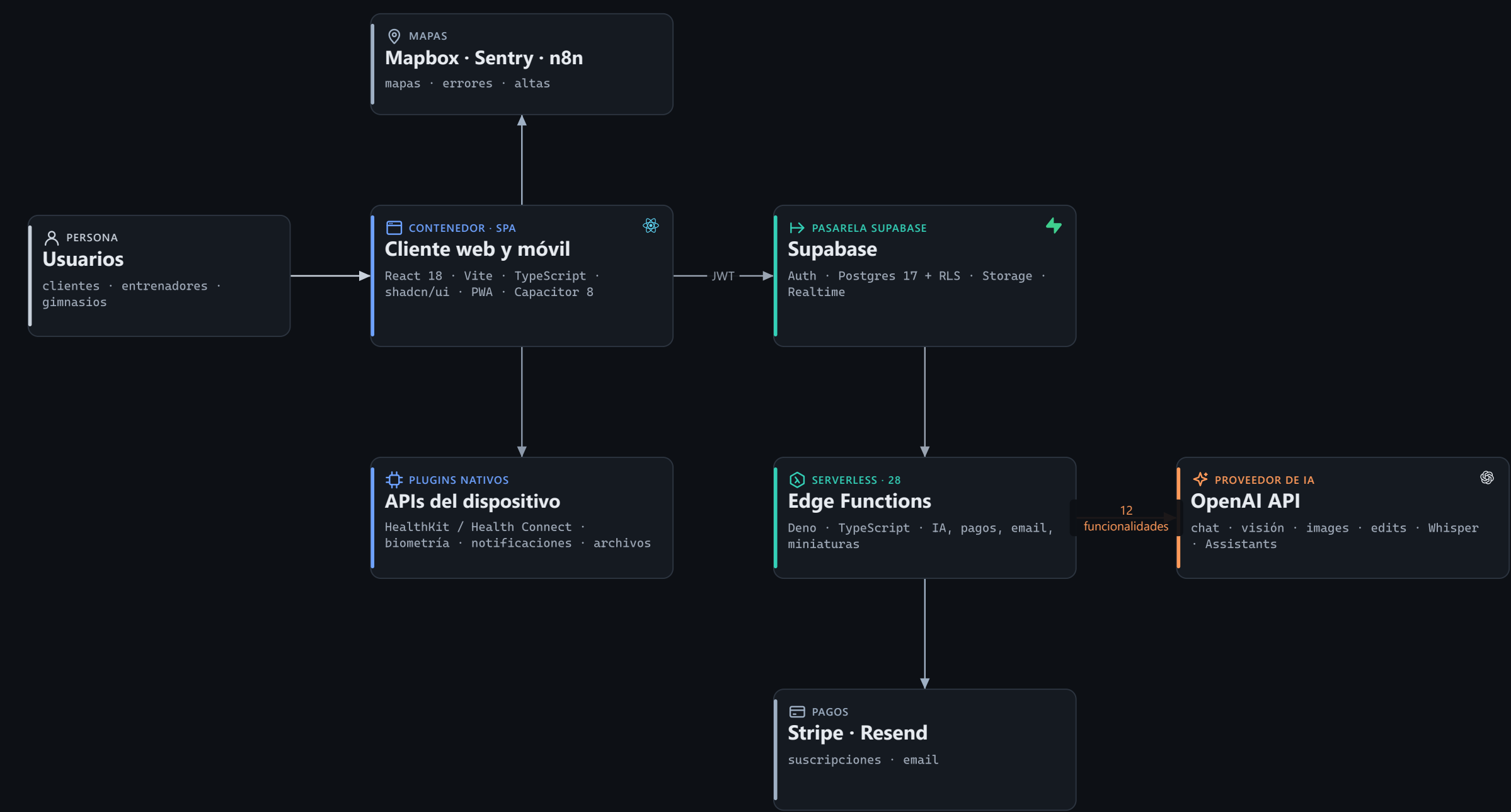


Foto al plato

Una SPA, tres plataformas; *claves solo en el servidor.*



28

Edge Functions: OpenAI, Stripe y Resend con secretos de servidor.

7 specs

con TDD sobre producción y despliegue mediante Supabase MCP.

109 + 100

tests en verde hoy; JSON Schema estricto en la frontera de la IA.

ICG Vault

Vota cine, series y videojuegos con un voto que pesa más cuanto más nivel tienes; colecciona, personaliza con IA y juega cada día.

13

módulos

63

funciones

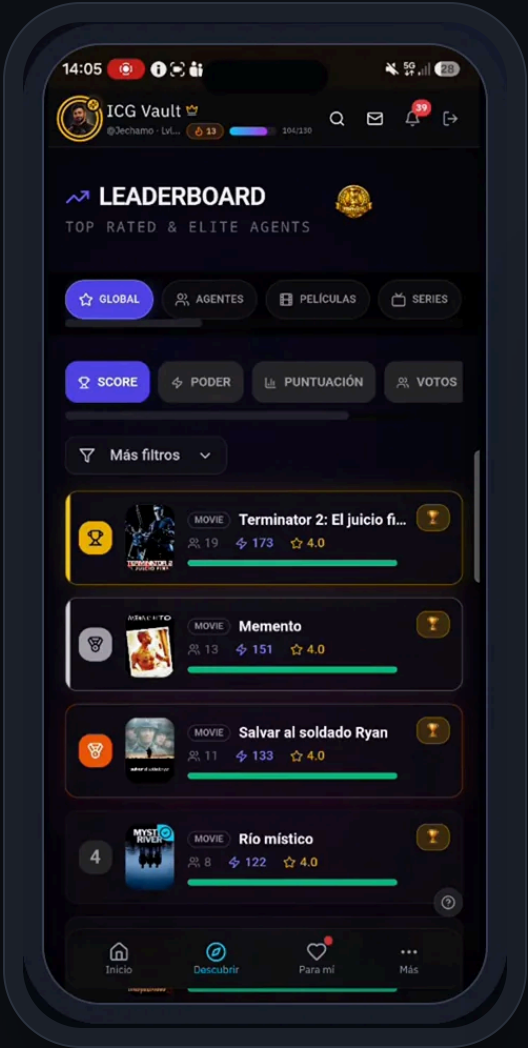
4

con IA

12

APIs

- Catálogo
- Votación y reseñas
- Rankings
- Perfil y progresión RPG
- Juegos diarios
- Juegos competitivos
- Comunidad
- Noticias y podcast
- Administración



Voto con poder



Avatares y guardianes con IA



Juegos diarios

Reglas del juego en SQL; *catálogo tras un proxy.*



175 RPC

voto ponderado, economía, cofres y juegos dentro de transacciones.

35

Edge Functions: TMDB, IGDB, HLTB, Metacritic y RSS con caché.

81 de 97

PR desde ramas de agentes, revisadas y fusionadas por el autor.

32 integraciones, 33 funcionalidades con IA.

	RRSS STUDIO	CHAFIT	ICG VAULT
Modelos de IA	Claude Code CLI · Gemini · fal.ai · HeyGen · ElevenLabs · Whisper local	OpenAI: texto, visión, imagen, edición, Whisper y Assistants	OpenAI: imagen, edición y borradores editoriales
Con IA	17 de 38	12 de 62	4 de 63
Otros servicios	Scrape Creators · GitHub · web analizada	Stripe · Mapbox · Resend · n8n · Sentry	TMDB · IGDB · HLTB · Metacritic · RSS · Google · Apple
Credenciales	Vault cifrado local	Secretos de Edge Functions	Secretos de Edge Functions
Control de coste	Plan y coste antes de gastar	Cupos por usuario	Rupias y acciones de administración

El sistema también *audita* lo ya construido.

DE EXTREMO A EXTREMO · SOLO LECTURA

1

orchestrator

diagnostica, reparte el trabajo y contrasta cada conclusión con el código y la base real.

2

database-expert

producción por MCP de Supabase (políticas, funciones, permisos, Storage), sin leer datos personales.

3

security-auditor

con la skill security-scan: OWASP Web 2025, API 2023, LLM 2025 y ASVS 5.0.

4

code-reviewer y performance-optimizer

buenas prácticas, arquitectura y rendimiento.

5

ux-designer

UI, usabilidad (Nielsen) y accesibilidad WCAG 2.2 AA.

Modelos de Anthropic, OpenAI y Google; ejecución observada por los hooks. Cada hallazgo lleva evidencia, corrección, riesgo del cambio y rollback.

CORRECCIONES PENDIENTES DE APLICAR

gate humano → spec + TDD

ChaFit

53

hallazgos · 15 críticos

Informe completo

Seguridad de aplicación

15

Datos y Edge Functions

13

Calidad de código

9

UI y accesibilidad

16

ICG Vault

48

hallazgos · 16 críticos

Informe completo

Seguridad

25

Calidad y rendimiento

16

UI y accesibilidad

7

crítica

deseable

mínima

Cómo se hizo

Informes completos en los repos privados de cada app: describen vulnerabilidades explotables · acceso para el tribunal

16 / 22

Tests ejecutados, *no declarados*.

375

comprobaciones del sistema
SDD: hooks, circuito, traza y
gates

209

RRSS Studio: 71 Vitest + 138 de
contrato, más 9 E2E sin red

209

ChaFit: 109 de contrato en
Node + 100 en Deno

0

ICG Vault: sin tests todavía; es
el primer paso del plan de
auditoría

- **run --fast** antes de commit, **run --slow** antes de push y **trace-audit** contra la base exacta en CI.
- Cobertura con trinquete (**48,3 %** en el sistema SDD): el umbral solo puede subir.

Desde el diseño, *no al final*.

- **Cada spec** declara su impacto de seguridad; si es sensible: control → tarea → test → evidencia.
- **OWASP** Web 2025, API 2023, LLM 2025 y ASVS 5.0 dentro del circuito.
- **Guardas**: ningún agente lee ni escribe secretos; los comandos destructivos se deniegan.
- **MCP** desactivado por defecto; Supabase, en solo lectura.
- ChaFit, spec 005: el asesor detectó una función invocable sin sesión → migración + rollback → **validado**.
- Claves de pago y de IA **nunca en el cliente**, en ninguno de los tres productos.
- Auditorías publicadas **solo como resumen saneado**.
- Cuentas demo **sin rol de administrador**; su contraseña se cambia tras la defensa.

Del temario a la *evidencia*.

46 / 54

competencias aplicadas con evidencia, 5 parciales y 3 no aplicadas, declaradas como tales

SDDRequisitos EARS

TDDPlaywright

ADRDocs as Code

Sentry

AGENTS.mdSkills

MCPOrquestación

Revisión de código con IA

APIs de IA

Multimodalidad

OWASP Web · API · LLMJWT

CI/CDCloud

Bases de datos

Apps móviles publicadasn8n

Low-code

Clean Architecture · parcial

Cobertura · trinquete

LLMOps · parcial

Docker · no

RAG · no

RESULTADOS

Lo que se puede *comprobar*.

17

specs del propio sistema, 114
tareas cerradas · v0.9.1

3

productos: uno greenfield y
dos en App Store y Google
Play

163

funcionalidades en 37
módulos, cada una con su
fichero

32

integraciones externas con
protocolo y credencial

7

specs con TDD sobre
producción en ChaFit

81

PR de agentes en ICG Vault,
revisadas por el autor

101

hallazgos de auditoría con
evidencia

56

vistas de arquitectura
generadas desde un único
modelo

Lo que me llevo.

- **La spec ahorra más de lo que cuesta cuando hay datos reales:** el fallo de ChaFit era un contrato implícito, no un bug.
- **La verificación tiene que vivir fuera del modelo:** un agente narra; un hook o un script demuestran.
- **Quien juzga no debe escribir,** y el orquestador debe contrastar: evitó una corrección que habría roto el alta en las apps instaladas.
- **La plataforma también opina:** los privilegios por defecto anularon un revoke aparentemente correcto.
- **Honestidad antes que cifras:** declarar lo no ejecutado y lo parcial da credibilidad.

CONCLUSIÓN

La IA escribe el código; *el sistema se asegura* de que esté bien hecho.

ENTREGA

Web del TFM

► Vídeo completo · 17:09

► Vídeo resumen · 8:47

Repositorio del TFM

CÓDIGO

Sistema SDD/TDD

Web del sistema

RRSS Studio

🔒 ChaFit

🔒 ICG Vault

Privados: claves de entorno en el historial y auditorías con vulnerabilidades. Acceso concedido al tribunal.

EN PRODUCCIÓN

chafit.es

icgvault.es

► ChaFit · recorrido

► ICG Vault · recorrido